

High Impact CVEs

Overview

Common Vulnerabilities and Exposures, commonly called CVEs, are publicly disclosed cybersecurity vulnerabilities assigned unique identifiers by the CVE Program. Security professionals use CVEs to identify, prioritize, remediate, and communicate software vulnerabilities consistently across organizations.

For Security Operations Center analysts, understanding high-impact CVEs is important for incident detection, vulnerability management, threat hunting, risk prioritization, and incident response.

CVE-2021-44228 — Log4Shell

Severity: Critical

Affected Software

- Apache Log4j 2

Description

Log4Shell is a remote code execution vulnerability affecting Apache Log4j 2. An attacker can send specially crafted input that causes a vulnerable application to perform a remote lookup and potentially download and execute malicious code.

SOC Analyst Considerations

- Identify vulnerable Log4j versions across the environment.
- Review application and web logs for exploitation attempts.
- Search for suspicious JNDI lookup strings.
- Monitor outbound LDAP, RMI, DNS, and HTTP connections.
- Apply vendor patches and mitigations immediately.
- Investigate compromised systems for persistence mechanisms.

CVE-2017-0144 — EternalBlue

Severity: Critical

Affected Software

- Microsoft Windows systems using SMBv1

Description

EternalBlue exploits a vulnerability in Microsoft Server Message Block version 1. It can allow remote code execution and was widely used in the WannaCry ransomware outbreak and the NotPetya destructive malware campaign.

SOC Analyst Considerations

- Disable SMBv1 where possible.
- Apply Microsoft security updates.
- Monitor SMB traffic between internal systems.
- Investigate signs of lateral movement.
- Search for ransomware and worm-like behavior.
- Review exposed systems for unauthorized access.

CVE-2014-0160 — Heartbleed

Severity: Critical

Affected Software

- Vulnerable versions of OpenSSL

Description

Heartbleed is an information disclosure vulnerability in OpenSSL. It can allow an attacker to read portions of server memory and potentially expose passwords, session cookies, encryption keys, and other sensitive information.

SOC Analyst Considerations

- Upgrade OpenSSL to a secure version.
- Replace potentially exposed certificates.
- Rotate private keys where exposure is possible.
- Reset passwords associated with affected systems.
- Monitor authentication logs for suspicious activity.
- Review systems for unauthorized access.

CVE-2023-34362 — MOVEit Transfer

Severity: Critical

Affected Software

- Progress MOVEit Transfer

Description

CVE-2023-34362 is a SQL injection vulnerability affecting Progress MOVEit Transfer. Successful exploitation may allow attackers to access the application database, deploy malicious components, and steal sensitive files.

SOC Analyst Considerations

- Apply vendor patches immediately.
- Review web server and application logs.
- Search for suspicious SQL activity.
- Investigate unauthorized file downloads.
- Check for web shells and persistence mechanisms.
- Review user accounts and administrative changes.

CVE-2024-3400 — Palo Alto PAN-OS GlobalProtect

Severity: Critical

Affected Software

- Palo Alto Networks PAN-OS
- GlobalProtect Gateway

Description

CVE-2024-3400 is a command injection vulnerability affecting certain Palo Alto Networks PAN-OS configurations. It may allow an unauthenticated remote attacker to execute commands on a vulnerable firewall.

SOC Analyst Considerations

- Install vendor updates and mitigations.
- Review firewall and GlobalProtect logs.
- Monitor unexpected administrative activity.
- Search for vendor-provided indicators of compromise.
- Validate firewall configuration integrity.
- Investigate unexpected files or processes.

CVE-2023-23397 — Microsoft Outlook

Severity: Critical

Affected Software

- Microsoft Outlook for Windows

Description

CVE-2023-23397 is a privilege escalation vulnerability that may allow an attacker to trigger an outbound authentication attempt by sending a specially crafted email. This can expose a user's NTLM authentication hash.

SOC Analyst Considerations

- Apply Microsoft security patches.
- Review Exchange and Outlook-related logs.
- Monitor outbound NTLM authentication attempts.
- Investigate suspicious email messages.
- Restrict unnecessary outbound SMB traffic.
- Reset credentials if compromise is suspected.

CVE-2019-0708 — BlueKeep

Severity: Critical

Affected Software

- Microsoft Windows Remote Desktop Services

Description

BlueKeep is a remote code execution vulnerability affecting Microsoft Remote Desktop Services. It can be exploited without authentication and has the potential to support worm-like propagation.

SOC Analyst Considerations

- Patch vulnerable systems.
- Restrict external exposure of Remote Desktop Protocol.
- Enable Network Level Authentication.
- Monitor failed and successful RDP logins.
- Investigate unusual remote sessions.
- Review endpoint alerts for exploit behavior.

CVE-2020-1472 — Zerologon

Severity: Critical

Affected Software

- Microsoft Windows Domain Controllers

Description

Zerologon is a vulnerability in Microsoft's Netlogon Remote Protocol. Successful exploitation may allow an attacker to impersonate a domain controller and gain highly privileged access within an Active Directory environment.

SOC Analyst Considerations

- Apply Microsoft security updates immediately.
- Review domain controller authentication logs.
- Investigate unusual machine account activity.
- Monitor privileged account changes.
- Search for unauthorized password resets.
- Rotate compromised credentials.

CVE-2023-4863 — libwebp

Severity: Critical

Affected Software

- libwebp
- Google Chrome
- Microsoft Edge
- Other applications that use libwebp

Description

CVE-2023-4863 is a heap buffer overflow vulnerability in the libwebp image library. An attacker may exploit it by causing a vulnerable application to process a specially crafted image.

SOC Analyst Considerations

- Patch affected browsers and applications.
- Update software components that depend on libwebp.
- Monitor browser and application crashes.
- Review endpoint detection alerts.
- Investigate suspicious image files.
- Verify software versions after remediation.

CVE-2018-8174 — Double Kill

Severity: Critical

Affected Software

- Microsoft Windows
- Internet Explorer
- Microsoft VBScript Engine

Description

CVE-2018-8174 is a remote code execution vulnerability in the Microsoft VBScript Engine. It may be exploited through a malicious website or a specially crafted document.

SOC Analyst Considerations

- Apply Microsoft security updates.
- Monitor suspicious browser activity.
- Review Microsoft Office document execution.
- Investigate exploit prevention alerts.
- Search for unusual child processes.
- Restrict unsupported or outdated software.

Best Practices for SOC Analysts

When responding to a newly disclosed or actively exploited CVE:

- Determine whether affected software exists in the environment.
- Identify affected versions and exposed systems.
- Prioritize vulnerabilities based on severity and exploitability.
- Check whether exploitation is occurring in the wild.
- Apply vendor patches or recommended mitigations.
- Monitor logs for indicators of compromise.
- Search for known attack techniques connected to the vulnerability.
- Review current threat intelligence.
- Investigate systems for persistence and lateral movement.

- Validate remediation after updates are applied.
 - Document findings, actions, and remaining risks.
 - Communicate risk and remediation status to stakeholders.
-

References

- CVE Program: <https://www.cve.org/>
- National Vulnerability Database: <https://nvd.nist.gov/>
- CISA Known Exploited Vulnerabilities Catalog: <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>